UNITÀ 1 · CYBERSECURITY · LEZIONE 3

Attaccanti: i cybercriminali

Chi attacca, perché lo fa, come si organizza e in quali fasi si muove. Per difendersi bisogna pensare come l'avversario.

5G TPSI Profili, economia del crimine, kill chain, MITRE ATT&CK

PER COMINCIARE

Secondo te, chi attacca più spesso un'azienda italiana?

SONDAGGIO

- **A** Un ragazzo annoiato
- **B** Un'organizzazione criminale, per soldi
- **C** Un servizio segreto straniero
- **D** Un dipendente scontento

PROFILI

Non esiste "l'hacker": esistono avversari diversi

Profilo	Motivazione	Risorse e pazienza
Script kiddie	Curiosità, sfida, notorietà	Strumenti già pronti, poca competenza
Cybercriminale	Denaro: riscatti, frodi, furto di dati da rivendere	Organizzazioni con ruoli e "fornitori"
Hacktivista	Ideologia, protesta politica	DDoS, defacement, fughe di documenti
Gruppo statale (APT)	Spionaggio, sabotaggio, influenza	Molto alte: mesi di lavoro, zero-day
Insider	Vendetta, denaro, oppure semplice errore	Accessi legittimi dall'interno

IL COLORE DEL CAPPELLO

Stesse competenze, scelte diverse

Attacca per profitto o per danneggiare.

È il cybercriminale di questa lezione.

Entra senza permesso, poi magari avvisa.

Anche con buone intenzioni, in Italia l'accesso abusivo resta un reato.

Lavora con l'autorizzazione del proprietario.

Penetration test con contratto, bug bounty, ricerca con divulgazione responsabile.

PUZZLE

Abbina ogni nome al suo profilo

LockBit	Gruppo attribuito alla Corea del Nord, noto per furti di criptovalute
NoName057(16)	Hacktivisti filorussi che lanciano DDoS anche contro siti italiani
Lazarus Group	Sabotaggio industriale attribuito a Stati, scoperto nel 2010
Stuxnet	Insider che usa una password mai revocata
Il tecnico licenziato	Gruppo di ransomware che "affittava" il proprio malware ad affiliati

IL CRIMINE COME SERVIZIO

Come funziona un'azienda criminale del ransomware

Sviluppatori RaaS

Forniscono malware, portale per i riscatti e sito per pubblicare i dati.

Broker di accessi

Vendono credenziali o accessi già ottenuti a reti aziendali.

Affiliati

Entrano, si muovono nella rete, rubano dati, lanciano il ransomware.

Riciclaggio

Ripuliscono i pagamenti in criptovaluta.

RaaS = **Ransomware as a Service**: gli sviluppatori trattengono una percentuale di ogni riscatto, il resto va all'affiliato.

METTITI ALLA PROVA

In un'operazione RaaS, chi materialmente entra nella rete della vittima?

QUIZ

A Di solito l'affiliato, a volte con un accesso comprato da un broker

B Lo sviluppatore del ransomware, che controlla tutto

C Il malware da solo, come un worm, senza nessuna persona

D Il servizio di riciclaggio, che deve verificare la vittima

LA PERSONA, PRIMA DEL COMPUTER

L'anello più debole

> **Il fattore umano è davvero l'anello più debole della sicurezza.**

Kevin Mitnick, ex hacker condannato negli anni Novanta, poi consulente di sicurezza, in *L'arte dell'inganno*, 2002



AL COMPUTER · 15 minuti

Decodifica un comando nascosto con CyberChef

Molti malware lanciano PowerShell con un comando codificato: `powershell -enc …`. Questo è innocuo, ma il trucco è lo stesso:

```
VwByAGkAdABlAC0ASABvAHMAdAAgACIAQwBpAGEAbwAgADUARwAiAA==
```

1. Apri **gchq.github.io/CyberChef** e incolla la stringa in Input.
2. Trascina nella Recipe **From Base64**, poi **Decode text** con UTF-16LE.
3. Annota il comando in **decodifica-cognome.txt**.

Controllo: ottieni un comando PowerShell che stampa un saluto alla classe. Senza il secondo passo vedi le lettere separate da caratteri vuoti.

LE FASI DI UN ATTACCO

La Cyber Kill Chain

1. **Ricognizione**: raccoglie informazioni sul bersaglio.
2. **Armamento**: prepara l'arma, per esempio un documento con macro.
3. **Consegna**: la recapita, via e-mail, link, chiavetta.
4. **Sfruttamento**: la vulnerabilità viene sfruttata.
5. **Installazione**: malware o accesso persistente.
6. **Comando e controllo** (C2): il malware contatta l'attaccante.
7. **Azioni sull'obiettivo**: furto di dati, cifratura, sabotaggio.

> Il difensore vince se **spezza un anello qualsiasi**: prima lo spezza, meno danni subisce.

PUZZLE

Un attacco vero, in ordine di kill chain

1. Su LinkedIn trova i nomi di chi lavora all'ufficio acquisti
2. Il codice installa un programma che si riavvia a ogni accensione
3. L'attaccante copia l'archivio dei clienti e poi lo cifra
4. L'impiegata abilita le macro e il codice parte
5. Il programma contatta ogni ora un server esterno per ricevere ordini
6. Prepara un finto ordine in Excel con una macro malevola
7. Lo invia a un'impiegata da un fornitore imitato

QUIZ A TRABOCCHETTO

Prepara un Word con macro malevola, ma non l'ha ancora inviato. Quale fase?

QUIZ

A Ricognizione

B Armamento

C Consegna

D Sfruttamento

IL VOCABOLARIO COMUNE

MITRE ATT&CK: il "perché" e il "come"

Una base di conoscenza pubblica di comportamenti di attaccanti reali, osservati negli incidenti.

- **Tattica** = l'obiettivo del momento: 14 colonne, da Reconnaissance a Impact.
- **Tecnica** = il modo per ottenerlo, con un codice: `T1566` Phishing.
- **Sotto-tecnica**: `T1566.001` allegato di spear phishing.
- Per ogni tecnica: gruppi che la usano, rilevamento, mitigazioni.

Tattica	Tecnica d'esempio
Initial Access	`T1566`
Credential Access	`T1110`
Lateral Movement	`T1021`
Impact	`T1486`

AL COMPUTER · 20 minuti

Indaga due tecniche su attack.mitre.org

1. Apri **attack.mitre.org** e cerca la tecnica `T1566`, poi `T1486`.
2. Per ciascuna annota: nome, tattica, una sotto-tecnica se c'è, due mitigazioni con il loro codice M….
3. Nella sezione dei gruppi trova un gruppo che usa T1566 e scrivi in una riga che cosa ha fatto.
4. Salva tutto in **attack-cognome.md**, con un titolo per ogni tecnica.

Controllo: T1566 è **Phishing**, tattica **Initial Access**; T1486 è **Data Encrypted for Impact**, tattica **Impact**. Tra le mitigazioni di T1566 trovi la formazione degli utenti.

IL CODICE PENALE

Che cosa rischia chi attacca, in Italia

Articolo c.p.	Reato
615-ter	Accesso abusivo a un sistema informatico
615-quater	Detenzione e diffusione abusiva di codici di accesso
635-bis	Danneggiamento di dati e programmi
640-ter	Frode informatica



AL COMPUTER · 30 minuti · a squadre

Ricostruisci l'attacco alla Officine Rossi

Il caso (inventato). Lunedì un dipendente riceve una falsa fattura PDF con un link. Inserisce la password su una pagina identica a quella aziendale. Mercoledì qualcuno entra in VPN con il suo account, senza MFA. Usa il Desktop remoto per raggiungere il server dei file, copia 40 GB verso un servizio cloud e venerdì notte cifra tutto, backup collegati compresi.

In **caso-squadra.md** fai una tabella: **Evento · Fase kill chain · Tattica ATT&CK · Tecnica · Contromisura**.

Controllo: almeno 6 righe. Ci sono di sicuro Initial Access, Lateral Movement, Exfiltration e Impact. La contromisura che ferma tutto mercoledì è la **MFA sulla VPN**.

BIGLIETTO D'USCITA

Completa prima di uscire

Un gruppo statale che resta a lungo nella rete si chiama _____.

Il modello in cui gli sviluppatori affittano il ransomware agli affiliati si chiama _____.

La sesta fase della kill chain è comando e _____.

In ATT&CK la tecnica T1566 si chiama _____.

L'accesso abusivo a un sistema informatico è punito dall'articolo _____ del codice penale.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Profili diversi: script kiddie, criminali, hacktivisti, Stati, insider
- Il ransomware è un'industria: broker, affiliati, RaaS
- La persona resta l'anello debole, ora anche con i deepfake
- Kill chain: 7 fasi, basta spezzarne una
- ATT&CK: tattiche e tecniche con un codice
- Prossima lezione: chi difende, e come

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.